Section 03

Industrial Security (Master)

Section 03 – Advanced Industrial Protocols

Advanced Industrial Protocols

Lecture Notes

Department of Computer Science

Outline – Section 03

Learning Objectives

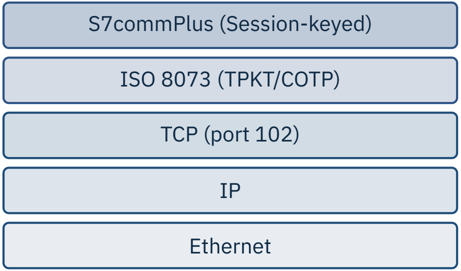
By the end of this section you will be able to

- Dissect S7commPlus, GOOSE, MMS and DLMS/COSEM down to the byte level.
- Understand the cryptographic anti-replay schemes in each.
- Recognise typical implementation defects (and how to fuzz for them).
- Build a custom Wireshark / Scapy dissector for a niche protocol.

1

S7commPlus

S7commPlus – The Encrypted-ish Successor

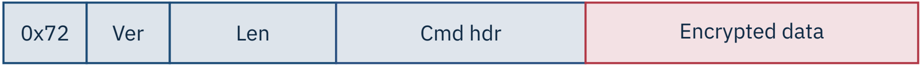


Session keys, not real crypto

Each session derives a key from challenges in the handshake – but the key derivation function (KDF) is fixed and reproducible. Several research groups have re-implemented it.

Source: Lei, C., He, J. et al., reverse-engineering of S7commPlus, multiple academic papers 2017–2020.

S7commPlus Frame Sketch



Open-source dissectors

`python-s7commplus` (gymgle, 2018) and `Plc4j` / `Plc4go` (Apache) both implement S7commPlus enough to read tags. Wireshark has a partial dissector.

2

IEC 61850 Stack

IEC 61850 – The Substation Stack

MMS	GOOSE	Sampled Values
ACSE/MMS, port 102	EtherType 0x88B8	EtherType 0x88BA

GOOSE has no authentication by default

Multicast L2 frames, sub-4 ms latency, sequence-number anti-replay only. IEC 62351 adds signatures but adoption in production substations is rare.

Source: IEC 61850 (multipart) | IEC 62351 (security for TC 57 protocols).

GOOSE Frame Anatomy

ETH header	AppID	Len	Reserved	goosePdu (ASN.1)

Known weakness

A spoofed GOOSE with a higher `stNum` (status number) is accepted instantly. Without IEC 62351-6, the only mitigation is L2 isolation.

Source: C. Kush, A. Ahmadian, P. Mahgoub, et al., academic GOOSE attack papers 2010–2018.

3

MMS & DLMS/COSEM

Section 03 – Advanced Industrial Protocols

MMS – Manufacturing Message Specification

- Application-layer ISO 9506, runs over OSI on TCP/IP (RFC 1006).
- Identifies named variables and methods on an IED.
- Used by IEC 61850 for client-server (HMI talks to IED here).
- No authentication by default; IEC 62351 part 4 adds TLS for MMS.

Why MMS matters

The HMI's read/write of named variables flows through MMS. If you can spoof or replay MMS, you can drive the IED's behaviour from the operator's perspective.

Source: ISO 9506 (Parts 1 and 2) | IEC 62351-4.

DLMS/COSEM – Smart Meters

Authentication levels

DLMS defines 0 (none), 1 (low, shared password), 2 (high, MD5/SHA-1), 3 (high-GMAC). German rollout (BSI TR-03109) mandates Gateway with X.509 + AES-GCM.

Source: IEC 62056 (DLMS/COSEM Blue/Green/Yellow/White books) | BSI TR-03109.

4

Building Dissectors and Fuzzers

Section 03 – Advanced Industrial Protocols

Custom Scapy Layer (sketch)

```python
from scapy.all import Packet, ByteField, ShortField, bind_layers, TCP

class MyVendor(Packet):
    name = "MyVendor"
    fields_desc = [
        ByteField("magic", 0x5A),
        ByteField("version", 1),
        ShortField("length", None),
    ]

bind_layers(TCP, MyVendor, sport=27015)
bind_layers(TCP, MyVendor, dport=27015)
```

First step

Capture a known-good session, hex-edit one byte at a time, replay – watch the device's reaction. That tells you which fields gate what.

Fuzzing ICS Protocols

Corpus capture → Mutator → Target PLC (bench only) → Crash monitor

Caution

Bench only Industrial devices crash on malformed input – often by tripping the safety system. *Never* fuzz production. Use a spare unit on a private VLAN.

Source: Tools: `boofuzz`, `kitty/katnip`, AFL++ for TCP harnesses.

Implementation Defects to Watch

- Integer overflows in length fields (Ripple20, URGENT/11, NUCLEUS:13).
- Out-of-bounds writes in ASN.1 parsers (MMS, GOOSE).
- Missing nonce checks in challenge-response auth (S7commPlus pre-2019).
- Hard-coded session keys after firmware update (multiple vendors).
- ICS PSIRT disclosures often reveal these for one product but the same code is in twenty others.

Source: Forescout Vedere Labs, *Project Memoria*: Ripple20, URGENT/11, NUCLEUS:13, NAME:WRECK, INFRA:HALT.

5

Defensive View

What an ICS IDS Can / Cannot See

Protocol	Detectable	Hidden
Modbus TCP	function code, addr, value	nothing – plain
S7commPlus	frame, command ID	encrypted payload
GOOSE	ETH header, AppID, stNum	multicast L2 only
DLMS/COSEM	AARQ, COSEM class IDs	encrypted, depending on level

Implication

Span-port IDS gives full visibility on legacy plaintext stacks and only partial visibility on session-keyed stacks. Plan host telemetry for the latter.

Summary – Section 03

Key Takeaway: Advanced protocols, in one breath

- S7commPlus session keying is reproducible – treat it as obfuscation, not crypto.
- GOOSE has no authentication by default; IEC 62351 changes this but adoption is rare.
- MMS and DLMS/COSEM both bolted security on later; rollouts have known weak modes.
- Custom dissectors (Scapy, Wireshark) unlock visibility on niche vendor protocols.
- Fuzz only on bench equipment – production devices crash unsafely.

References – Section 03

- IEC 61850 (multipart). *Communication networks and systems for power utility automation*.
- IEC 62351 (multipart). *Security for IEC TC 57 protocols*.
- ISO 9506. *Manufacturing Message Specification (MMS)*, Parts 1 & 2.
- IEC 62056. *DLMS/COSEM* (Blue/Green/Yellow/White books).
- BSI TR-03109. *Smart Metering System Specifications*.
- Beresford, D. *Exploiting Siemens Simatic S7 PLCs*, BlackHat USA, 2011.
- Gordeychik, S. *SCADA StrangeLove* talks and tools, 2014–2018.
- Forescout Vedere Labs. *Project Memoria* – Ripple20, URGENT/11, NUCLEUS:13, NAME:WRECK, INFRA:HALT.
- Wireshark Foundation. ICS protocol dissector documentation.
- Scapy contributors. *Scapy User Manual*, ICS protocol modules.
- `boofuzz` project (Joshua Pereyda). `https://boofuzz.readthedocs.io`.
- Apache Software Foundation. *Plc4x* (Plc4j, Plc4go, Plc4py).

End of Section 03

Advanced Industrial Protocols

Questions and discussion

IS Security